CAPSTONEPROJECTSOLUTION

OSCORP RACCOMANDAZIONI

RISTRUTTURAZIONE PROFESSIONALE IN ITALIANO

Set di raccomandazioni basato sull’assessment NIST condotto. Le raccomandazioni dovrebbero essere prioritizzate in ordine di importanza.

Documento	Capstone Project Solution: Raccomandazioni
Lingua	Italiano
Fonte	Capstone Project Solution.pdf
Nota	Ristrutturazione del contenuto originale

Uso: portfolio / documentazione di progetto

CAPSTONE PROJECT SOLUTION: RACCOMANDAZIONI

Di seguito viene presentato un set di raccomandazioni basato sull'assessment NIST condotto.

Le raccomandazioni dovrebbero essere prioritizzate in ordine di importanza.

1. Cyber Security Governance

• Assumere un Cyber Security Manager o un Chief Information Security Manager.

• Formalizzare ruoli e responsabilità di cyber security. Assicurarsi che il consiglio di amministrazione sia consapevole dei propri doveri in materia di information security.

• Redigere una policy completa di information security. La policy deve essere approvata dal senior management.

• Investire nell'assunzione di professionisti di cyber security per stabilire e gestire una pratica di cyber security.

2. Asset Management

• Identificare e classificare tutti gli asset in base a criticità e sensibilità.

• Condurre revisioni periodiche per assicurare che il CMDB sia accurato e aggiornato.

3. Third Party Risk Management

• Creare un processo per identificare e gestire i fornitori terzi. Il processo dovrebbe partire dall'identificazione dei fornitori, dalla classificazione dei fornitori e dallo svolgimento di assessment periodici di sicurezza sui fornitori terzi.

4. Cyber Security Risk Management

• Creare un processo per valutare e gestire i rischi di cyber security.

• Il processo dovrebbe prioritizzare i rischi in base alla criticità e all'impatto sul business.

• Il processo dovrebbe essere approvato dall'audit and risk committee e dall'attuale team di risk management.

• Creare un registro dei rischi cyber per documentare tutti i rischi di cyber security.

• Raccomandare un programma di internal audit che includa la cyber security nello scope.

5. Identity and Access Management

• Implementare e distribuire l'autenticazione a due fattori in tutta l'organizzazione come priorità.

• Seguire il principio del least privilege e della separation of duties in tutta l'organizzazione.

• Rivedere gli utenti amministratori, eliminare la condivisione delle password amministrative e implementare un controllo degli accessi basato sui ruoli.

• Condurre revisioni regolari degli accessi utente per assicurare che i principi di access management siano seguiti in modo coerente.

6. Security Education and Awareness

• I dipendenti dovrebbero svolgere formazione di security almeno una volta ogni 12 mesi.

• Considerare l'esecuzione di attacchi di phishing simulati per migliorare ulteriormente la consapevolezza.

7. Data Security and DLP

• Svolgere un’attività di data discovery. Classificare ed etichettare i dati in base a sensibilità e criticità.

• Utilizzare Microsoft Azure AIP per etichettare i dati.

• Considerare l’implementazione di una soluzione DLP. Una soluzione Microsoft DLP potrebbe essere la scelta migliore, dato che l’ambiente utilizza prodotti Microsoft.

• Bloccare l’utilizzo delle chiavette USB. Consentirlo solo temporaneamente quando esiste una giustificazione business.

8. Detection and Response

• Investire in una soluzione SIEM. Questa può essere gestita tramite un Managed Security Service Provider (MSSP) oppure internamente. La rilevazione degli incidenti di cyber security è una priorità.

• Creare un piano enterprise-wide di cyber security incident response e almeno 5 piani di risposta agli incidenti cyber per le tipologie di attacco più comuni.